ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Schneider Electric Modicon M580 ePAC (BMEP58/BMEH58) - read from "M540" · Component type: **Embedded Device (EDR) - PLC/PAC** · Target SL = SL 3

Where to work	**EcoStruxure Control Expert** (Security Editor: user profiles & access rights; application / file-encryption / data-storage passwords). CPU **cybersecurity rotary switch** (Standard/Advanced/Reset) on the BMEP58 back; the Ethernet **Security tab › Enforce Security**; IPsec via BMENOC0301 / BMENUA0100 modules.
Interfaces / ports	Modbus/**UMAS 502**; HTTP/**HTTPS 80/443** (HTTPS from FW v4.10); FTP/TFTP (disable); **SNMP 161**; EtherNet/IP **44818**; IPsec (via NOC/NUA). Config over Control Expert (Modbus/UMAS).
Firmware note	Modicon **M580 ePAC** (BMEP58•040 standalone / BMEH58•040 Hot Standby / Safety S CPUs). Patch known UMAS/Modbus issues — **CVE-2021-22779 (ModiPwn)**, **CVE-2022-45789** — and enforce the application password. Confirm CPU catalog + firmware in Control Expert.
How to read	Default read-only (Control Expert read-only project, .STU review). Native how-to + external-tool validation + pass. Write/exploit tools = isolated env + written authorization. (Read as the Schneider Modicon PLC intended by "M540".)

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user I&A;	In Control Expert enable the **Security Editor** (user profiles + access rights) so engineering access authenticates per user; set the **application password** so opening/modifying the project requires it. **Test:** open/modify the app without the password -> denied; each user is challenged. **Ext. tools:** Control Expert (Security Editor review); ReadOnlyEnum.	Engineering access authenticates per user; application password required; no anonymous program access.	EDR.
SR/CR 1.2	Device & process I&A;	Set the **cybersecurity switch to Advanced** and apply **Enforce Security** so **Access Control (IP allow-list)** limits which clients connect; use **IPsec** (BMENOC/BMENUA) for authenticated comms. Native UMAS/Modbus are unauthenticated -> rely on app password + ACL + IPsec. **Test (isolated):** a non-allow-listed IP to 502 is blocked; an unauthenticated UMAS write is refused. **Ext. tools:** Wireshark (UMAS/Modbus/IPsec); Modbus/UMAS client (isolated); Nmap.	Only allow-listed / IPsec peers connect; unauthenticated UMAS writes refused (app password + ACL).	ModiPwn compensating controls.
SR/CR 1.3	Account management	EcoStruxure Control Expert › **Security Editor**: manage user profiles/accounts (create/modify/disable), remove defaults, assign least-privilege profiles; the Security Editor centrally governs who may open/modify/download. **Ext. tools:** Control Expert (Security Editor user/profile review).	Named least-privilege accounts; no shared/default; centrally managed in the Security Editor.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers in the Security Editor and a unique device identity (IP/device name) on the **Ethernet Security** tab; no identifier reuse. **Ext. tools:** Control Expert (Security Editor + Ethernet config).	Unique user and device identifiers; no reuse.	
SR/CR 1.5 / 1.7	Authenticator & password strength	Confirm the **application password**, **file-encryption password** (.STU/.STA/.ZEF), and **data-storage password** (IEEE 1686) are set and strong; Security-Editor password policy; change all defaults. **Ext. tools:** Control Expert (password/policy review).	Strong app/file/data-storage passwords set (IEEE 1686); defaults changed.	
SR/CR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.8	PKI certificates	For **HTTPS** (FW v4.10+) and **IPsec** (BMENOC0301 / BMENUA0100), review the certificate configuration (valid, not the default self-signed where a CA is available) and renew/replace as needed. **Ext. tools:** Browser cert view; openssl (validity/chain).	Valid certificates for HTTPS/IPsec; default self-signed replaced where possible.	
SR/CR 1.9	Strength of public key auth	Confirm HTTPS/IPsec use strong keys/algorithms (>=2048 RSA / ECC); no weak or expired certificates. **Ext. tools:** testssl.sh (:443); openssl x509 (key/algorithm).	Strong certificate/key crypto; weak/expired certs absent.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.10	Authenticator feedback	Confirm Control Expert and the web interface mask password entry (no cleartext echo). **Ext. tools:** Visual verification at login.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Control Expert Security Editor has **limited native lockout**; verify what exists and compensate with the ACL/IPsec + upstream controls. Record the gap if absent. **Ext. tools:** Repeated invalid logins (authorized) to characterize behavior.	Lockout where available; otherwise Partial + compensating (ACL/IPsec/segmentation).	Known limitation.
SR/CR 1.12	System use notification	No native PLC logon banner; enforce the approved use-notification banner on the Control Expert **engineering workstation** (Windows GPO) as a compensating control. **Ext. tools:** EWS GPO / secpol review.	Approved banner on the engineering workstation (Partial if no PLC-level banner).	Compensating (EWS).
SR/CR 1.13	Access via untrusted networks	Segment the PLC; firewall **502/TCP**; IPsec/VPN for cross-zone; Access Control allow-list; no direct UMAS/Modbus from untrusted networks. **Ext. tools:** Nmap by segment (502/44818/80/443); firewall + ACL review.	PLC unreachable from untrusted networks; brokered, authenticated access.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	In the Security Editor confirm per-user **access rights** (read / modify / debug / configure / security) follow least privilege. **Test:** a read-only user cannot download or change configuration. **Ext. tools:** Control Expert (access-rights review); attempt privileged action as read-only user.	Least privilege enforced per access right; privileged actions denied.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control the CPU **SD card** and USB/console, and enforce a removable-media policy on the Control Expert EWS; only authorized project files (.STU/.STA) are loaded. **Ext. tools:** Physical inspection; EWS removable-media policy review.	SD/USB controlled at the CPU and the EWS; only authorized media used.	
SR/CR 2.4 (+ EDR 2.4)	Mobile code	No general-purpose mobile code runs on the PLC; confirm only the compiled application executes and no untrusted DTM/add-on content runs; the file-encryption password protects the project. **Ext. tools:** Control Expert (project / DTM review).	Only the trusted compiled application runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	No PLC-side idle lock; enforce workstation lock on the Control Expert EWS. **Ext. tools:** Manual idle test on the EWS.	EWS auto-locks; changes require re-auth.	Compensating.
SR/CR 2.6	Remote session termination	Confirm engineering (UMAS) connections can be dropped (Control Expert disconnect) and that the CPU connection timeout closes idle sessions; the Access-Control allow-list limits who can reconnect. **Ext. tools:** Control Expert (connection status); Wireshark (session).	Remote sessions terminable on demand and on inactivity timeout.	
SR/CR 2.7	Concurrent session control	Confirm concurrent programming access is controlled — the application password + reservation prevent conflicting simultaneous programming; monitor active connections. **Ext. tools:** Control Expert (reservation/connection review).	Concurrent privileged/programming sessions limited or monitored.	
SR/CR 2.8 / 2.12	Auditable events & non-repudiation	Enable **Syslog** PLC event logging (over TCP) to the SIEM; review the diagnostic buffer / events (logins, program changes, mode/keyswitch, security). **Test:** a program change is logged with the Security-Editor user + time. **Ext. tools:** Syslog listener (`nc 514`); Control Expert diagnostics.	Security events logged with user + time; forwarded to syslog/SIEM.	
SR/CR 2.9	Audit storage capacity	The PLC diagnostic buffer / Syslog events are finite — offload **Syslog** (over TCP) to the SIEM for retention; confirm the SIEM sizes storage and alerts before capacity. **Ext. tools:** SIEM/syslog retention review.	Events offloaded and retained; alert before capacity.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/syslog collector alerts if PLC event forwarding fails; events are surfaced, not silently lost. **Ext. tools:** SIEM alerting configuration review.	Audit-processing failures alerted with a defined response.	
SR/CR 2.11	Timestamps	Confirm NTP time sync via the CPU/NOC and consistent event timestamps. **Ext. tools:** Wireshark (NTP); Control Expert time review.	Accurate synced time; consistent timestamps.	
EDR 2.13	Physical diagnostic & test interfaces	Control the CPU physical interfaces: the **cybersecurity rotary switch**, SD-card slot, and USB/console; keep the CPU in a locked panel and enable **CPU memory protection** (configured physical input bit). **Ext. tools:** Physical inspection; Control Expert (memory-protection config).	Physical/diagnostic interfaces controlled; memory protection engaged; panel sealed.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1 / 4.1	Communication integrity & confidentiality	Enable **IPsec** (BMENOC0301 / BMENUA0100) for authenticated/encrypted comms and **HTTPS** (FW v4.10+); disable HTTP/FTP/TFTP; the application password protects UMAS integrity. Confirm in-scope links are protected. **Ext. tools:** Wireshark (confirm IPsec/HTTPS; no cleartext UMAS on critical links); testssl.sh (:443).	In-scope comms IPsec/HTTPS-protected; cleartext services disabled.	
SR/CR 3.2 / 3.4 (+ EDR 3.2)	Malicious code & software integrity	Load only **Schneider-signed firmware**; enable **data memory protection** (FW V3.20+) and **CPU memory protection** (configured physical input bit); protect the project with the application + file-encryption passwords. **Ext. tools:** Firmware signature verify on update; se.com checksum.	Only signed firmware runs; memory protection on; project integrity protected.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change, re-verify the **Security tab (Enforce Security applied)**, Security Editor, memory protection, and IPsec, and compare the .STU against the baseline; confirm disabled services stayed disabled. **Ext. tools:** Control Expert compare; Nmap (confirm FTP/TFTP/HTTP/SNMP off).	Security settings match the hardening baseline after change.	
SR/CR 3.5	Input validation	Patch UMAS/Modbus CVEs (ModiPwn); confirm the CPU tolerates malformed UMAS/Modbus frames. **ISOLATED only:** fuzz and observe CPU/connection health. **Ext. tools:** UMAS/Modbus fuzzer (ISOLATED); Wireshark; Control Expert diagnostics.	Patched against known CVEs; no crash/major fault on malformed input.	
SR/CR 3.6	Deterministic output	Verify configured **fallback/fail-safe behavior** — output-module fallback values and the CPU behavior on STOP / comm loss (configured fallback) — so outputs assume a defined safe state. **Ext. tools:** Control Expert (I/O fallback configuration review).	Outputs go to a defined/fail-safe state on fault, STOP, or comm loss.	
SR/CR 3.7	Error handling	Confirm application + system fault handling (system words/bits %S, diagnostic buffer) handles errors gracefully without loss of control or info leakage. **Ext. tools:** Control Expert diagnostics / system words review.	Graceful fault handling; no crash, unsafe state, or info leak.	
SR/CR 3.8	Session integrity	Where IPsec/HTTPS is applied, sessions are integrity-protected; the application password protects UMAS integrity against replay/tamper on engineering links. **Ext. tools:** Wireshark (IPsec/UMAS session inspection).	Sessions integrity-protected on secured links; replay/tamper prevented.	
SR/CR 3.9	Protection of audit information	Protect the Syslog transport (TCP; TLS where supported) and the SIEM store, and restrict access to PLC diagnostic data so records cannot be altered/deleted by unauthorized users. **Ext. tools:** SIEM access-control review.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10 / EDR 3.11	Updates & physical tamper	Signed firmware update with rollback; use the **cybersecurity switch** + memory-protect input; keep the CPU in a locked panel; control the SD card. **Ext. tools:** Control Expert / Unity Loader (authorized); physical inspection.	Signed updatable with rollback; physical/memory protection engaged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	The CPU accepts only **Schneider-signed firmware** (product-supplier root of trust); confirm the signing chain is intact and unsigned/altered firmware is rejected at load. **Ext. tools:** Unity Loader / Control Expert firmware verify; se.com checksum.	Supplier signing root intact; unsigned/altered firmware rejected.	EDR-specific.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
EDR 3.13	Provisioning asset-owner roots of trust	Where IPsec/HTTPS uses asset-owner certificates (BMENUA0100 / customer PKI), confirm the asset owner can provision and manage its own certificates/keys; else record the compensating control. **Ext. tools:** Certificate configuration review (BMENUA0100 / PKI).	Asset-owner certificate provisioning supported/verified, or compensating control recorded.	EDR-specific.
EDR 3.14	Integrity of the boot process	Confirm the CPU validates **signed-firmware integrity before execution**; no unsigned/tampered firmware runs. Capture firmware version + signature status. **Ext. tools:** Control Expert / Unity Loader (firmware version/signature).	Firmware integrity validated before execution; only signed firmware boots.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.2	Information persistence	On decommission or repurpose, clear the CPU application/memory (Control Expert memory reset / firmware clear) and wipe/destroy the SD card so project logic and configuration are not recoverable. **Ext. tools:** Control Expert (clear memory); SD-card sanitize/destroy.	Sensitive project/config data purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Confirm HTTPS (TLS) and IPsec use strong parameters; file-encryption + data-storage passwords protect project/data at rest; disable weak/legacy protocols. **Ext. tools:** testssl.sh / sslyze (:443); Wireshark (IPsec).	Strong TLS/IPsec; project/data encrypted at rest; weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1 / 5.2	Segmentation & boundary	Confirm the PLC is in a segmented cell zone; **Access Control** allow-list + firewall at the boundary restrict UMAS/Modbus/EtherNet-IP; NOC modules and IDMZ enforce the boundary. **Ext. tools:** Nmap by zone; firewall + Access-Control review.	PLC segmented; only approved flows cross the boundary.	
SR/CR 5.3	General Purpose Person-to-Person Communication Restrictions	**N/A.** Embedded device has no general-purpose person-to-person communications (email/IM/web).	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 5.4	Application Partitioning	**N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer).	N/A - justification recorded (not assessed as a control).	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1 / 6.2	Audit accessibility & monitoring	Confirm Syslog events reach the SIEM and are readable/exportable; passive OT monitoring on the cell segment. **Ext. tools:** Syslog listener; passive OT monitor (Claroty/Nozomi).	Events accessible/exportable; forwarded to SIEM; monitoring active.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	**Enforce Security** disables unused services (FTP/TFTP/HTTP/EtherNet-IP/SNMP/DHCP-BOOTP); connection limits; use **Hot Standby (BMEH58)** for availability; segmentation. **ISOLATED:** flood test. **Ext. tools:** Traffic generator (ISOLATED); Control Expert diagnostics.	PLC keeps controlling under load; unused services off; HSBY where critical.	
SR/CR 7.2	Resource management	Confirm the CPU limits resource exhaustion — the M580 DoS-hardening and connection limits, plus CPU load/scan-time headroom, prevent a single flood from denying control; monitor scan time and connection count. **Ext. tools:** Control Expert (CPU load / scan time); traffic generator (ISOLATED).	Resources bounded; no exhaustion-based loss of control under load.	
SR/CR 7.3 / 7.4	Backup & recovery	Save the **.STU/.STA** project (encrypted) + SD-card image; test restore on a spare CPU; Hot Standby failover where used. **Ext. tools:** `sha256sum` of project; Control Expert restore (lab).	Verified project + SD backup; restore/failover tested.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6 / 7.7	Config baseline & least functionality	Verify **Enforce Security** is applied and settings match the Schneider hardening baseline; disable all unused protocols/services; change default ports. **Ext. tools:** Nmap (open services); Control Expert Security tab review.	Enforce Security applied; only required services enabled; baseline met.	
SR/CR 7.8	Component inventory	Capture CPU catalog (BMEP58•040 / BMEH58•040), firmware, and modules (NOC/NUA/RIO) via Control Expert. **Ext. tools:** Control Expert inventory; ReadOnlyEnum.	Complete CPU/firmware/module inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
EcoStruxure Control Expert (Security Editor)	Native config, RBAC, passwords, audit (all)	Open the project read-only; review the Security Editor (users/access rights), application/file/data-storage passwords, the Security tab (Enforce Security), and diagnostics.	Read-only; unlock only for change tests.
Project backup (.STU/.STA) + sha256sum	Baseline, drift, recovery (3.4, 7.3)	Export the encrypted project + SD image; hash to detect drift; restore on a lab CPU.	File-encryption password protects it.
Wireshark / tcpdump	Comm integrity (1.2, 3.1)	SPAN/tap; filter `modbus || umas`; confirm IPsec/HTTPS on in-scope links and whether UMAS/Modbus is cleartext.	Passive; SPAN/tap only.
Modbus / UMAS test client	Unauthenticated-protocol / ModiPwn exposure (1.2, 3.5)	Read-only queries to confirm exposure; in an isolated env, verify app-password + ACL block unauthenticated writes and that CVEs are patched.	ISOLATED for write tests; authorization.
Nmap / PortQry	Port/service exposure & segmentation (1.13, 5.x, 7.7)	`nmap -sT -p 502,80,443,161,44818,21,69 -T2` ; scan by zone; confirm FTP/TFTP/HTTP/SNMP closed after Enforce Security.	Tune timing on production.
testssl.sh / sslscan	HTTPS/TLS strength (3.1, 4.3)	`testssl.sh https://:443`; confirm TLS + strong ciphers (FW v4.10+).	Read-only.
Syslog listener (nc / rsyslog)	Log offload verification (2.8, 6.x)	Stand up a listener; trigger a program/security change; confirm the PLC forwards it to the SIEM.	Coordinate with SIEM team.
Passive OT monitor (Claroty / Nozomi / Dragos)	Monitoring & inventory (6.2, 7.8)	Passively observe the cell segment for asset inventory, UMAS/Modbus exposure, and anomalies.	Passive only.
Nessus / OpenVAS	Known-CVE scan incl. ModiPwn (3.2, 3.5)	Authenticated/careful scan for known Modicon CVEs; cross-check Schneider SEVD advisories.	ISOLATED/representative; authorization.

Tool / method	Verifies	How to use — steps / example	Constraints
UMAS/Modbus fuzzer / traffic generator	Input validation & DoS resilience (3.5, 7.1)	Malformed/high-rate frames while watching CPU/connection health.	ISOLATED/non-production; authorization.
ReadOnlyEnum	Host/network/protocol enumeration (7.8)	Enumerate exposed services/protocols read-only.	Read-only.

Controlled - Project Use · Independent Assurance Authority · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.